Requisitos de seguridad - estado final

Fecha: 22/10/2026. Versión técnica: 061330d. Adaptación didáctica de ENS RD 311/2022 y NIST SP 800-53 Rev. 5; no acredita conformidad completa. Referencias y condiciones en fuentes.md. Estado: cumplido, parcial o pendiente según evidencia, sin atribuir resultados no ejecutados.

ID	Estado	Implementación y referencia	Prueba y evidencia
SEG-01	Parcial	Exclusiones de archivos sensibles; custodia en Bitwarden. IA-5 apoya gestión de autenticadores; Git es requisito propio	Escáner de todo el historial: sin patrones encontrados. Hubo exposición en chat/captura y queda rotación personal pendiente; incidencias.md
SEG-02	Cumplido	pg y módulos server-only; nunca NEXT_PUBLIC para secretos. IA-5, relación parcial	Chromium comprueba HTML y JS contra contraseña efímera y cadenas PostgreSQL; sin coincidencias. No equivale a auditoría exhaustiva
SEG-03	Parcial	Perfil gestor, scrypt, sesión HMAC 4 h, HttpOnly/Secure en HTTPS/SameSite Strict, autorización GET/POST/PUT/DELETE y Origin exacto. ENS op.acc.4.1	Pruebas locales sin sesión: 401 y BD idéntica. Origen ajeno: 403. Pruebas remotas en pruebas.md
SEG-04	Parcial	Rol app CRUD, migrator propietario separado, RLS limitado a app. ENS op.acc.4.2 y AC-6	Usuario confirma SQL ejecutado. CRUD remoto preparado pero no ejecutado por bloqueo; falta prueba de denegación DDL y auditoría de membresías con la cuenta real
SEG-05	Cumplido	Zod estricto de servidor, límites, enumeraciones, tipos, UUID y evidencia. NIST SI-10 y apoyo ENS mp.sw.1	Vacío, texto largo, valor ajeno, P=4, score inyectado y JSON malformado rechazados; unitarias/API
SEG-06	Parcial	PostgreSQL en desarrollo y Preview; SQLite solo pruebas aisladas. DATABASE_URL_ADMIN solo local. ENS mp.sw.1 como apoyo	Secretos efímeros de prueba distintos, SESSION_SECRET Preview rotado. Falta configurar y verificar BD PostgreSQL de desarrollo distinta de Preview
SEG-07	Cumplido	Errores públicos genéricos con referencia; diagnóstico interno solo operation, code, reference, fecha. Requisito del laboratorio, apoyo op.exp.2	Entradas inválidas sin SQL, rutas, stacks ni credenciales; logger por lista blanca, no serializa excepciones
SEG-08	Parcial	Commits por etapas, lockfile, Preview y etiqueta entrega-l2. Requisito del laboratorio	Versiones y pruebas documentadas; faltan aportaciones personales identificadas, URL repositorio confirmada y acceso profesor

Explicación de decisiones

Se requieren GRANT y políticas RLS: conceder privilegios a una tabla no autoriza automáticamente sus filas. Se concede acceso solo al rol del servidor. La contraseña no se almacena en claro: scrypt con sal; el secreto HMAC es distinto. El servidor valida y calcula la puntuación aunque el navegador sea modificado. Una medida propuesta no reduce el riesgo. Los errores internos se identifican por referencia sin divulgar datos de conexión.

Limitaciones: un único perfil compartido, sin identidad individual ni MFA. El límite global de 30 solicitudes de acceso por intervalo de 15 minutos también cuenta accesos correctos y puede bloquear temporalmente a un usuario legítimo. Cerrar sesión elimina la cookie local; rotar SESSION_SECRET invalida todas. La CSP conserva inline por Next y unsafe-eval exclusivamente en desarrollo.

Bloqueo final verificado

La Preview de parte 2 está Blocked por permisos del autor Git (Vercel), no por un fallo de construcción. La URL estable conserva parte 1. Las pruebas remotas requeridas siguen pendientes. SEG-03 se considera **parcial en el despliegue** aunque su implementación y pruebas locales estén completas; SEG-08 permanece parcial. La rotación de SESSION_SECRET está guardada en Preview y surtirá efecto al lograr un despliegue nuevo Ready.

Pruebas de seguridad y funcionamiento

Fecha: 22/10/2026. Commit técnico: 061330d3f8fc5cc6c5e7f115ac50ad190a3cc025. Windows, Node 24.21.0, Next 16.4.2, Chromium Playwright. Resultados realmente ejecutados:

Prueba	Resultado	Evidencia	Límite
Construcción y TypeScript	Correcto	npm.cmd run build	No valida el proveedor
Nueve combinaciones	Correcto	tests/domain.test.ts, lib/scoring.ts	Función pura invocada solo por servidor y pruebas
Validación	Correcto	Vacío, longitud excesiva, enum inválido, tipos, P fuera de rango, score inyectado, evidencia vacía	5 pruebas unitarias en total
Persistencia local	Correcto	Crear ambos ejemplos, recargar navegador y editar responsable	SQLite aislada solo de prueba
Escritura no autorizada	Correcto	POST, PUT, DELETE 401; lectura autorizada antes/después idéntica	API local; prueba remota registrada debajo
Origen y sesión	Correcto	Origen externo 403, cookie HttpOnly/SameSite, logout y 401	Secure se aplica en producción HTTPS
Cálculo en servidor	Correcto	API evaluation prueba las nueve combinaciones; score no se acepta como entrada	El navegador no calcula clasificación
XSS y secretos navegador	Correcto	Texto img no crea imagen; HTML y todos los scripts cargados sin contraseña efímera ni conexión PostgreSQL	Comprobación por marcadores/patrones, no auditoría formal
Historial Git	Correcto en revisión ejecutada	scripts/check-secrets.mjs recorre blobs únicos de todos los commits; evidencia tmp/evidence/secret-scan.json	No detecta todos los formatos posibles ni resuelve exposición en chat

Las nueve combinaciones

Probabilidad	Impacto	Puntuación	Nivel
1	1	1	Bajo
1	2	2	Bajo
1	3	3	Medio
2	1	2	Bajo
2	2	4	Medio
2	3	6	Alto
3	1	3	Medio
3	2	6	Alto
3	3	9	Alto

Reproducción

npm.cmd test; npm.cmd run build; npm.cmd run test:e2e. Navegador en tmp/browsers. La prueba fija DATABASE_URL y DATABASE_URL_ADMIN vacías y genera secretos distintos, por lo que nunca modifica la BD de Preview. El informe de escáner no contiene valores. Verificación remota: node scripts/test-preview.mjs URL_PREVIEW, usando sesión efímera firmada con un secreto de prueba que no se imprime y protección de despliegue vía CLI oficial. No prueba la contraseña personal del gestor.

Incidencias anteriores conservadas: fallo RLS (42501) y origen no autorizado. Se corrigen con políticas del rol y alias estable. No se ocultan fallos ni se desactiva RLS.

Resultado remoto de esta parte

NO EJECUTADO: Vercel bloqueó el despliegue dpl_CZGfjGSB5JuhUp3JJYqfynHwkcWo por falta de permisos del autor de commits. inspect: target preview, status Blocked. El titular confirmó que no puede corregir la vinculación GitHub/Vercel ahora. No se han ejecutado ni se dan por aprobadas las pruebas 3 y 4 sobre la nueva versión remota.

La migración SQL fue confirmada sin errores por el usuario, pero no se leyó la conexión administrativa ni se suplantó al propietario. La prueba automatizada scripts/test-preview.mjs está preparada: crea un riesgo ficticio, lo recupera en peticiones separadas, comprueba edición y rechazo sin sesión sin cambiar BD, y retira únicamente su registro de prueba. Ejecutarla cuando la Preview sea Ready.

Resultado local final: 5 unitarias correctas; 1 prueba integral Chromium correcta con todas sus aserciones; construcción y TypeScript correctos. Revisión del historial con 68 blobs en la ejecución del commit técnico: 0 hallazgos de los patrones buscados. El escáner se vuelve a ejecutar al cerrar la entrega.

Commit de las pruebas finales ejecutadas: 08c42e215027c94355342dfc84834d6f3dba2e4d. Incluye comparación literal de las nueve combinaciones y comprobación de contraseña, hash y secreto efímeros ausentes del JS enviado al navegador.

Registro del grupo

Integrantes confirmados por el usuario: **Alex Serrano, Alba Prats y Tomás Juan**. Fecha: 22/10/2026. Entrega completa: viernes 30/10/2026 a las 23:59, PDU, una por grupo.

Quién hizo qué

Integrante	Trabajo y commits propios
Alex Serrano	Pendiente de indicar y contrastar con su cuenta GitHub
Alba Prats	Pendiente de indicar y contrastar con su cuenta GitHub
Tomás Juan	Interlocución y configuración del proveedor comunicada en el chat; pendiente de confirmar reparto y vincular commits personales

Los commits generados por el asistente utilizan la identidad ya configurada en este repositorio; no acreditan por sí mismos participación individual. No se reescribe el historial ni se crean autores ficticios. Cada integrante debe revisar, aportar y guardar sus cambios con su cuenta. Quién realiza la entrega: pendiente de confirmar.

Decisiones revisadas

El usuario identifica como revisión compartida los fallos de acceso tratados en la conversación y el contraste de tecnologías. Se concretan las decisiones documentadas sin atribuirlas individualmente:

- La IA propuso inicialmente conceder permisos CRUD como solución al acceso. La comprobación mostró que RLS seguía bloqueando las filas. Se corrigió mediante políticas solo para laboratorio_app, manteniendo RLS. La diferencia entre privilegios de tabla y políticas por fila explica por qué GRANT no bastaba.

- Se contrastó la integración Supabase SDK con una conexión PostgreSQL de servidor. Se eligió pg y Transaction pooler para conservar los secretos en servidor y aplicar un rol mínimo. Las dependencias Supabase añadidas previamente por el usuario no se retiran sin necesidad; no se emplean para autenticar este perfil.

- La parte 1 calculaba el nivel también en el navegador. La parte 2 lo corrige: función única de servidor y endpoint de evaluación; el navegador solo presenta el resultado.

Cada integrante debe completar con sus palabras una decisión revisada, qué cambió y por qué, y asociarla a sus commits. Esta revisión individual está pendiente; la lista anterior no la sustituye.

Pregunta de cierre

Recomendamos primero copias separadas y restauración completa probada. Protege la conservación de registros confirmados y permite medir si el servicio vuelve antes de incumplir el plazo de siete días. Simularíamos la pérdida de instancia en pruebas, restauraríamos la copia y compararíamos integridad, recuentos y matrículas completas. Mediríamos RPO y RTO contra los límites aprobados por dirección; 1 hora y 4 horas son propuestas, no requisitos ya aprobados. La medida sigue siendo propuesta hasta implantarla y aportar evidencia; no reduce automáticamente la valoración inicial.

Repositorio remoto configurado localmente: https://github.com/Tomaxplosion/Lab2. Visibilidad privada y acceso del profesor pendientes de verificación; no se inventan esas evidencias.